

Mapeo de Preguntas y Métricas a Requisitos Normativos

Esta tabla vincula las **preguntas GQM** y **métricas CWE** del marco nacional con requisitos y buenas prácticas de referencia (ENS, ISO/IEC 27001/27002/27004, NIS2 y documentación internacional sobre CWE/CVE/CVSS). [web:22][web:9][web:14][web:24]

Meta GQM	Pregunta (Q)	Métrica (M)	Referencias ENS (ES)	ISO/IEC 27001 / 27002 / 27004	NIS2 / UE	CWE / Otros
G1 Reducir prevalencia CWE	G1Q1 – Proporción de vulnerabilidades explicadas por CWE Top 25	M1.1 – % de vulnerabilidades mapeadas a CWE Top 25	ENS – Análisis y gestión de riesgos, medidas de protección	ISO 27005 (gestión de riesgos), ISO 27004 (métricas de seguridad)	NIS2 – Art. 21 (medidas de gestión de riesgos)	CWE Top 25 Methodology, NVD, CVE/CVSS. [web:28] [web:27] [web:22]
G1	G1Q2 – Distribución de debilidades por sector	M1.2 – Distribución % por CWE Top 25 y sector	ENS – Principio de proporcionalidad y categorización por sistemas	ISO 27002 – A.6 Organización de la seguridad de la información	NIS2 – Clasificación de entidades esenciales/importantes por sector	ENISA Threat Landscape (análisis sectoriales). [web:9] [web:14]
G1	G1Q2	M1.3 – Ranking Top 10 CWE por sector	ENS – Medidas de seguridad por categoría de sistema	ISO 27004 – Definición de indicadores sectoriales	NIS2 – Evaluaciones sectoriales de riesgo	CWE Top 25 aplicado a sectores concretos. [web:28] [web:22]
G1	G1Q3 – Evolución de debilidades de diseño vs. implementación	M1.4 – % diseño vs. implementación	ENS – Requisitos de diseño seguro de sistemas	ISO 27002 – A.14 Desarrollo y mantenimiento de sistemas	NIS2 – Medidas técnicas “state of the art”	CWE-1000 Research Concepts, CWSS. [web:7] [web:22]
G1/G2	G1Q4 – Severidad media por CWE	M2.1 – CVSS medio por CWE	ENS – Priorización de riesgos según impacto	ISO 27005 – Evaluación de impacto; ISO 27004 – indicadores de riesgo	NIS2 – Requisitos de proporcionalidad y priorización	CVSS estándar, CWE-CVE mapeo. [web:28] [web:22]
G2 Mejorar detección/remediación	G2Q1 – Peso de CWE asociadas a vulnerabilidades KEV	M2.2 – % de vulnerabilidades con CWE en KEV	ENS – Gestión de incidentes y respuesta	ISO 27002 – A.16 Gestión de incidentes	NIS2 – Notificación de incidentes significativos	Catálogo KEV (CISA) y sus mapeos a CWE/CVE. [web:2]

G2	G2Q2 – Tiempo de remediación por CWE	M3.1 – Tiempo medio de remediación por CWE prioritaria	ENS – Gestión de incidentes y vulnerabilidades	ISO 27002 – A.12.6 Gestión de vulnerabilidades técnicas	NIS2 – Gestión de incidentes y medidas correctivas	Prácticas de métricas de tiempos de parcheo; CWE vinculada a CVE/SLAs. [web:9] [web:14]
G2	G2Q3 – Efecto de las acciones de mitigación	M3.2 – Variación interanual de vulnerabilidades por CWE	ENS – Mejora continua	ISO 27004 – Seguimiento longitudinal de métricas	NIS2 – Revisión periódica de medidas de seguridad	CWE Top 25 año a año, cambios de ranking. [web:28] [web:1]
G3 Integrar CWE en regulación	G3Q1 – Inclusión de CWE en pliegos y auditorías	M4.1 – % de pliegos con CWE/Top25	ENS – Política de seguridad y contratación TIC	ISO 27001 – Cláusula 8 Operación, compras	NIS2 – Obligaciones para la cadena de suministro	Documentación CWE recomendada para adquisición de software/hardware. [web:22]
G3	G3Q1	M4.2 – % de auditorías que evalúan CWE	ENS – Auditoría bienal, verificación de medidas	ISO 27001 – Cláusula 9 Evaluación del desempeño	NIS2 – Supervisión y ejecución	Guías CCN, uso de CVE/CWE en auditorías.
G4 Desarrollar capacidades /cultura	G4Q1 – Integración de CWE en procesos internos	M4.3 – % de organizaciones que usan CWE como taxonomía formal	ENS – Organización y responsables de la seguridad	ISO 27002 – A.6 Organización de la seguridad de la información	NIS2 – Gobernanza interna de la ciberseguridad	ENISA sobre uso de taxonomías comunes para intercambio de información. [web:22] [web:9]
G4	G4Q1	M4.4 – % que mapean vulnerabilidades a CWE	ENS – Gestión de vulnerabilidades	ISO 27002 – A.12.6; ISO 27004 – métricas	NIS2 – Reporte y gestión de vulnerabilidades	CWE / CVE / CVSS como triada estándar. [web:22] [web:27]

G4	G4Q2 – Capacidad de detección frente a CWE prioritarias	M4.5 – % de herramientas que soportan CWE	ENS – Medidas de protección, herramientas técnicas	ISO 27002 – A.12 Operación y medidas técnicas	NIS2 – Medidas técnicas “state of the art”	ENISA sobre herramientas y estándares para clasificación de debilidades. [web:22]
G4	G4Q3 – Madurez cultural y formativa	M8.1 – Nº de profesionales formados en CWE	ENS – Formación y concienciación	ISO 27002 – A.7 Seguridad en Recursos Humanos	NIS2 – Requisitos de capacitación	Estrategias de competencias en ciberseguridad (p.ej. iniciativas UE). [web:8] [web:9]
G4	G4Q3	M8.2 – % de organizaciones con repositorio unificado con CWE	ENS – Registro y monitorización	ISO 27002 – A.12.4 Registro y monitorización	NIS2 – Gestión de registros y reporte	ENISA – estándares y herramientas para intercambio de información. [web:22]

Esta tabla puede ampliarse con más columnas (p.ej. “Guía nacional específica”, “Referencia CWE concreta”) según evolucionen las normativas y las guías técnicas nacionales.